



Réalisation Technique

Sujet :
Analyse de la Sécurité Web avec
OWASP ZAP

RÉALISÉ par : Darius ILOKI NZOUSSI



TABLE DES MATIERES

I. INTRODUCTION	3
I.1 Résumé	3
II. PRÉSENTATION DE LA RÉALISATION	3
II.1 Contexte	3
II.2 Objectifs et problématique	4
II.2.1 Objectifs.....	4
II.2.2 Problématique	4
III. ANALYSE FONCTIONNELLE	4
IV. PLAN D'IMPLÉMENTATION.....	4
1. Préparation de l'environnement	4
Installation de Docker sur la machine hôte Debian 12.....	17
Déploiement de DVWA avec la commande docker run --rm -it -p 80:80 vulnerables/web-dvwa	18
Téléchargement et installation d'OWASP ZAP depuis le site officiel, lancement en mode Standard.....	21
Installation et configuration de OWASP ZAP :	21
Configuration du proxy dans Firefox (127.0.0.1, port 8080) ou utilisation du navigateur intégré à ZAP.	23
➤ Vérification de l'interception du trafic en accédant à	25
Exploration de l'interface (arborescence des sites, historique, outils comme Spider et Fuzzer).....	28
Intégration et exercices pratiques avec DVWA :	28
Connexion à DVWA (admin/password) et réglage du niveau de sécurité sur "Low".	28
Réalisation d'exercices : injection SQL avec 1' OR '1'='1, XSS avec <script>alert('XSS')</script>, fuzzing sur le module Brute Force, injection de commandes avec 127.0.0.1 && whoami.	29
Tests préliminaires des vulnérabilités via ZAP (interception, modification des requêtes, analyse des réponses).....	29



I. INTRODUCTION

I.1 Résumé

Dans le cadre d'un atelier pratique de 3h30 intégré à ma formation, j'ai réalisé un projet technique portant sur l'analyse de la sécurité web à l'aide d'OWASP ZAP (Zed Attack Proxy) et de la Damn Vulnerable Web Application (DVWA). Ce TP, effectué dans un environnement isolé via Docker, m'a permis d'explorer les tests de pénétration d'applications web en configurant ZAP comme proxy d'interception, en identifiant des vulnérabilités courantes et en documentant mes résultats. Cette expérience m'a offert une initiation concrète aux techniques de sécurité web, renforçant mes compétences en analyse de vulnérabilités, en manipulation des requêtes HTTP et en rédaction professionnelle de rapports, tout en exploitant un environnement sécurisé et contrôlé.

II. PRÉSENTATION DE LA RÉALISATION

II.1 Contexte

OWASP ZAP est un outil open-source dédié aux tests de sécurité des applications web, permettant d'intercepter et d'analyser le trafic HTTP pour détecter des failles telles que les injections SQL ou le XSS. DVWA, une application volontairement vulnérable, offre un cadre pédagogique pour simuler des attaques de manière légale. Ce projet, réalisé lors d'un TP de 3h30, a consisté à déployer ces outils dans un environnement Docker pour garantir l'isolation et la sécurité des tests. L'objectif était de maîtriser OWASP ZAP, d'exploiter des vulnérabilités sur DVWA et de produire une documentation structurée des résultats.



II.2 Objectifs et problématique

II.2.1 Objectifs

- ❖ Installer et configurer un environnement de test avec Docker et DVWA.
- ❖ Configurer OWASP ZAP pour intercepter et analyser le trafic web.
- ❖ Identifier et exploiter des vulnérabilités web courantes (injection SQL, XSS, fuzzing, injection de commandes).
- ❖ Documenter les failles découvertes de manière professionnelle.
- ❖ Explorer les bases des tests de pénétration dans un cadre sécurisé.

II.2.2 Problématique

Comment utiliser OWASP ZAP pour analyser et exploiter efficacement les vulnérabilités d'une application web dans un environnement isolé, tout en développant une approche méthodique pour documenter les résultats ?

III. ANALYSE FONCTIONNELLE

OWASP ZAP, associé à DVWA dans un conteneur Docker, constitue une solution complète pour l'apprentissage des tests de sécurité web. Ses principales fonctionnalités utilisées dans ce projet incluent :

- ❖ **Proxy d'interception** : Capture et modification des requêtes HTTP entre le navigateur et l'application.
- ❖ **Exploration automatique (Spider)** : Cartographie des pages et paramètres de DVWA.
- ❖ **Fuzzing** : Test automatisé d'entrées pour détecter des failles.
- ❖ **Manipulation manuelle** : Utilisation du Requester pour personnaliser les attaques. DVWA, avec son niveau de sécurité ajustable (Low), permet de simuler des vulnérabilités comme l'injection SQL, le XSS ou l'injection de commandes. Docker assure une isolation totale, protégeant le système hôte des manipulations effectuées durant le TP.

IV. PLAN D'IMPLEMENTATION

1. Préparation de l'environnement :



New Virtual Machine Wizard

Ready to Create Virtual Machine

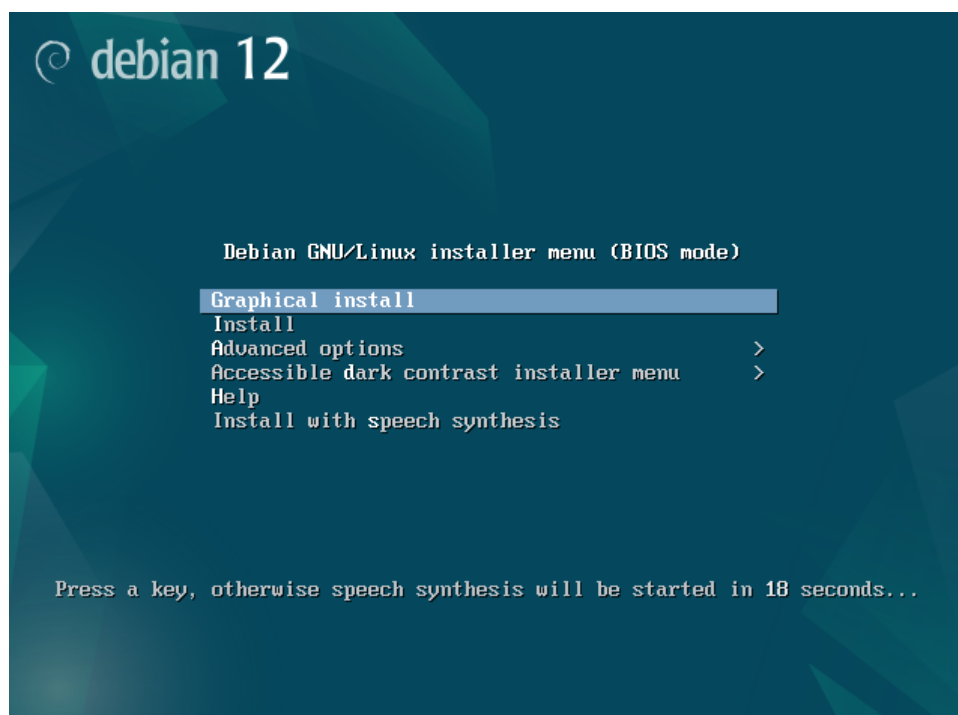
Click Finish to create the virtual machine. Then you can install Debian 11.x 64-bit.

The virtual machine will be created with the following settings:

Name:	Srv-zap
Location:	C:\Users\dariu\OneDrive\Documents\Virtual Machine...
Version:	Workstation 17.x
Operating System:	Debian 11.x 64-bit
Hard Disk:	20 GB, Split
Memory:	2048 MB
Network Adapter:	Bridged (Automatic)
Other Devices:	CD/DVD, USB Controller, Printer, Sound Card

Customize Hardware...

< Back Finish Cancel



L'installation de Debian 12 peut se faire en mode graphique ou en mode console, mais nous allons choisir le mode graphique.



Select a language

Choose the language to be used for the installation process. The selected language will also be the default language for the installed system.

Language:

Chinese (Simplified)	- 中文(简体)
Chinese (Traditional)	- 中文(繁體)
Croatian	- Hrvatski
Czech	- Čeština
Danish	- Dansk
Dutch	- Nederlands
Dzongkha	- ཇོང་ཁ།
English	- English
Esperanto	- Esperanto
Estonian	- Eesti
Finnish	- Suomi
French	- Français
Galician	- Galego
Georgian	- ქართული
German	- Deutsch

Comme dans de nombreux assistants d'installation, il faut sélectionner la langue d'installation, de préférence celle du pays d'où la distribution est installée.



Choix de votre situation géographique

Le pays choisi permet de définir le fuseau horaire et de déterminer les paramètres régionaux du système (« locale »). C'est le plus souvent le pays où vous vivez.

La courte liste affichée dépend de la langue précédemment choisie. Choisissez « Autre » si votre pays n'est pas affiché.

Pays (territoire ou région) :

Belgique
Canada
France
Luxembourg
Suisse
Autre



debian 12

Configurer le clavier

Disposition de clavier à utiliser :

Danois
Néerlandais
Dvorak
Dzongkha
Espéranto
Estonien
Éthiopien
Finnois
Français
Géorgien
Allemand
Grec
Gujarati
Gourmoukhi
Hébreu
Hindi
Hongrois

Capture d'écran Revenir en arrière Continuer

Il est ensuite possible de sélectionner le type de clavier associé à la machine pour l'installation.

debian 12

Configurer le réseau

Veuillez indiquer le nom de ce système.

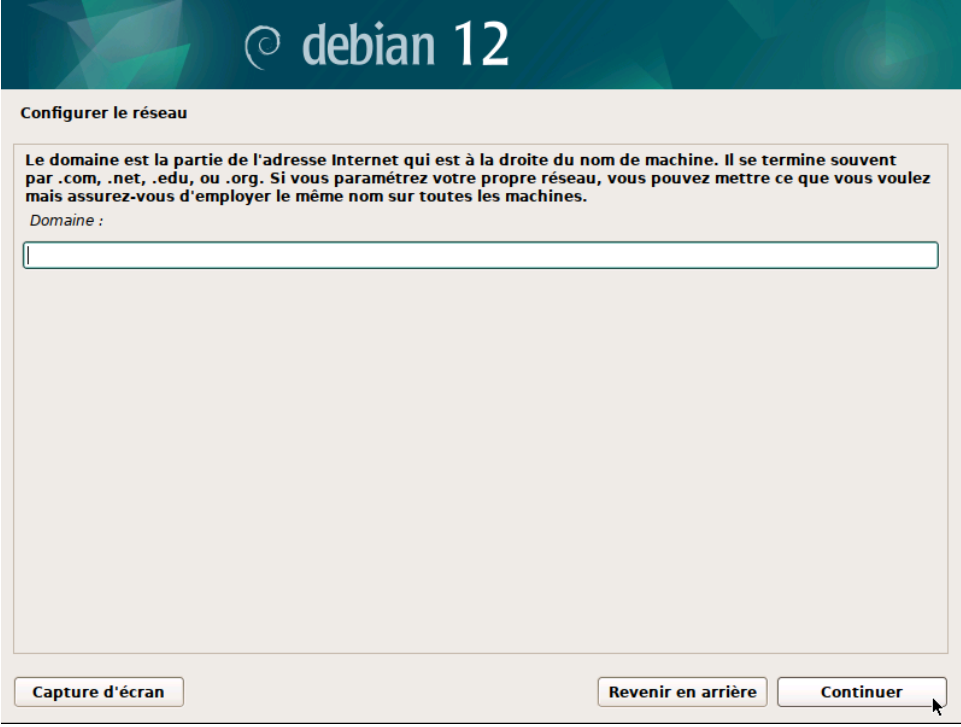
Le nom de machine est un mot unique qui identifie le système sur le réseau. Si vous ne connaissez pas ce nom, demandez-le à votre administrateur réseau. Si vous installez votre propre réseau, vous pouvez mettre ce que vous voulez.

Nom de machine :

Srv-zap

Capture d'écran Revenir en arrière Continuer

Une fois le CD ou DVD détecté, la configuration est automatiquement déterminée, puis l'assistant propose de nommer la nouvelle machine.



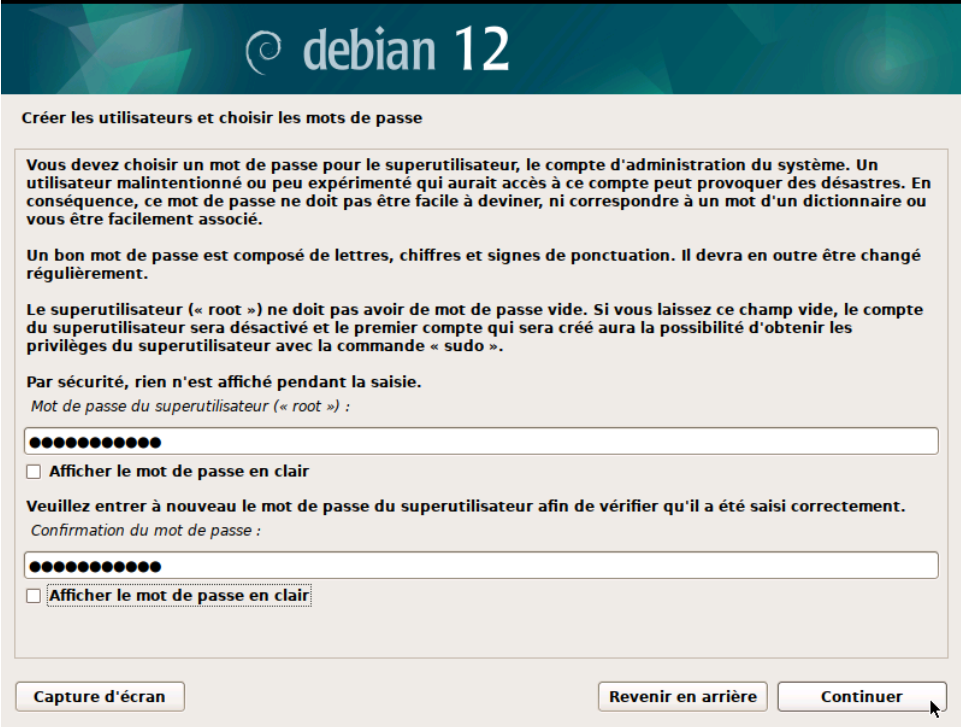
debian 12

Configurer le réseau

Le domaine est la partie de l'adresse Internet qui est à la droite du nom de machine. Il se termine souvent par .com, .net, .edu, ou .org. Si vous paramétrez votre propre réseau, vous pouvez mettre ce que vous voulez mais assurez-vous d'employer le même nom sur toutes les machines.

Domaine :

On peut proposer un nom de domaine si la machine fait partie d'un ensemble plus large, pour notre cas on laisse ce champ vide.



debian 12

Créer les utilisateurs et choisir les mots de passe

Vous devez choisir un mot de passe pour le superutilisateur, le compte d'administration du système. Un utilisateur malintentionné ou peu expérimenté qui aurait accès à ce compte peut provoquer des désastres. En conséquence, ce mot de passe ne doit pas être facile à deviner, ni correspondre à un mot d'un dictionnaire ou vous être facilement associé.

Un bon mot de passe est composé de lettres, chiffres et signes de ponctuation. Il devra en outre être changé régulièrement.

Le superutilisateur (« root ») ne doit pas avoir de mot de passe vide. Si vous laissez ce champ vide, le compte du superutilisateur sera désactivé et le premier compte qui sera créé aura la possibilité d'obtenir les privilèges du superutilisateur avec la commande « sudo ».

Par sécurité, rien n'est affiché pendant la saisie.

Mot de passe du superutilisateur (« root ») :

☐ Afficher le mot de passe en clair

Veillez entrer à nouveau le mot de passe du superutilisateur afin de vérifier qu'il a été saisi correctement.

Confirmation du mot de passe :

☐ Afficher le mot de passe en clair

Ici on va choisir un mot de passe pour le compte super utilisateur root.

2.



L'assistant propose de créer un compte d'administration distinct de root, permettant de gérer le système avec des droits délégués.

Nous allons garder le même nom pour l'identifiant du compte



debian 12

Créer les utilisateurs et choisir les mots de passe

Un bon mot de passe est composé de lettres, chiffres et signes de ponctuation. Il devra en outre être changé régulièrement.

Mot de passe pour le nouvel utilisateur :

☐ Afficher le mot de passe en clair

Veillez entrer à nouveau le mot de passe pour l'utilisateur, afin de vérifier que votre saisie est correcte.

Confirmation du mot de passe :

☐ Afficher le mot de passe en clair

Capture d'écran

Revenir en arrière

Continuer

Il faut également fournir un mot de passe pour ce nouveau compte utilisateur, en veillant à le choisir suffisamment fort, car il dispose des droits d'administration du système.

debian 12

Partitionner les disques

Le programme d'installation peut vous assister pour le partitionnement d'un disque (avec plusieurs choix d'organisation). Vous pouvez également effectuer ce partitionnement vous-même. Si vous choisissez le partitionnement assisté, vous aurez la possibilité de vérifier et personnaliser les choix effectués.

Si vous choisissez le partitionnement assisté pour un disque complet, vous devrez ensuite choisir le disque à partitionner.

Méthode de partitionnement :

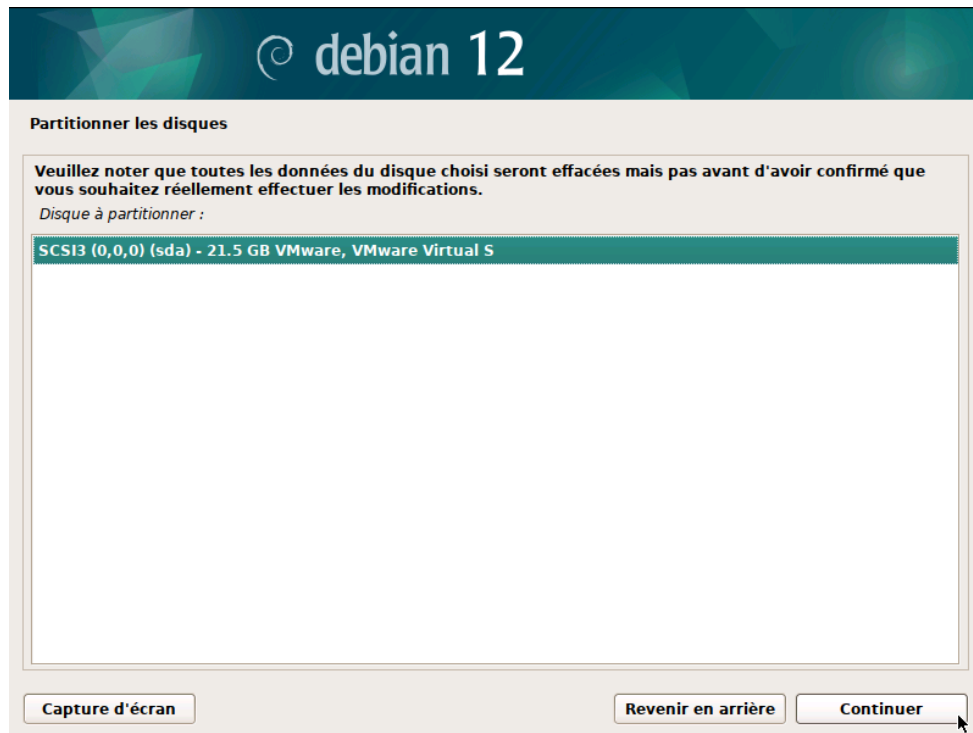
- Assisté - utiliser un disque entier
- Assisté - utiliser tout un disque avec LVM
- Assisté - utiliser tout un disque avec LVM chiffré
- Manuel

Capture d'écran

Revenir en arrière

Continuer

Ensuite, il faut choisir le mode de partitionnement, nous ont choisis Assisté-utiliser un disque entier, et il est possible de chiffrer la partition ou de procéder à un découpage manuel et personnalisé.



À ce stade, l'assistant devrait être capable de détecter le disque virtuel préalablement créé, et l'affichage correspondant devrait apparaître.



Il faut choisir le mode de partitionnement, nous on choisit Tout dabs une seule partition.



 **debian 12**

Partitionner les disques

Voici la table des partitions et les points de montage actuellement configurés. Vous pouvez choisir une partition et modifier ses caractéristiques (système de fichiers, point de montage, etc.), un espace libre pour créer une nouvelle partition ou un périphérique pour créer sa table des partitions.

Partitionnement assisté

Configurer le RAID avec gestion logicielle

Configurer le gestionnaire de volumes logiques (LVM)

Configurer les volumes chiffrés

Configurer les volumes iSCSI

SCSI3 (0,0,0) (sda) - 21.5 GB VMware, VMware Virtual S

> n° 1 primaire 20.4 GB f ext4 /

> n° 5 logique 1.0 GB f swap swap

Annuler les modifications des partitions

Terminer le partitionnement et appliquer les changements

Capture d'écran

Aide

Revenir en arrière

Continuer

Sur cette page, nous avons les informations sur notre partition.

 **debian 12**

Partitionner les disques

Si vous continuez, les modifications affichées seront écrites sur les disques. Dans le cas contraire, vous pourrez faire d'autres modifications.

Les tables de partitions des périphériques suivants seront modifiées :
SCSI3 (0,0,0) (sda)

Les partitions suivantes seront formatées :
partition n° 1 sur SCSI3 (0,0,0) (sda) de type ext4
partition n° 5 sur SCSI3 (0,0,0) (sda) de type swap

Faut-il appliquer les changements sur les disques ?

☐ Non

☒ Oui

Capture d'écran

Continuer

On peut alors choisir de répondre "Oui" pour procéder à l'installation, ou annuler si l'on ne souhaite pas écraser le contenu du disque virtuel utilisé.

Analyse de la Sécurité Web avec OWASP ZAP

Darius ILOKI NZOUSSI



debian 12

Configurer l'outil de gestion des paquets

L'analyse des supports d'installation a trouvé l'étiquette :

Debian GNU/Linux 12.4.0 _Bookworm_ - Official amd64 NETINST with firmware 20231210-17:56

Vous pouvez maintenant analyser des médias supplémentaires qui seront utilisés par l'outil de gestion des paquets (APT). En principe, ils devraient appartenir au même ensemble que le média d'amorçage. Si vous n'avez pas d'autres supports disponibles, vous pouvez passer cette étape.

Si vous souhaitez analyser d'autres supports, veuillez en insérer un autre maintenant.

Faut-il analyser d'autres supports d'installation ?

☒ Non

☐ Oui

Capture d'écran

Revenir en arrière

Continuer

debian 12

Configurer l'outil de gestion des paquets

L'objectif est de trouver un miroir de l'archive Debian qui soit proche de vous du point de vue du réseau. Gardez à l'esprit que le fait de choisir un pays proche, voire même votre pays, n'est peut-être pas le meilleur choix.

Pays du miroir de l'archive Debian :

- Corée du Sud
- Costa Rica
- Croatie
- Danemark
- Espagne
- Estonie
- Finlande
- France**
- Grèce
- Géorgie
- Hong Kong
- Hongrie
- Inde
- Indonésie
- Iran

Capture d'écran

Revenir en arrière

Continuer

L'assistant détecte automatiquement le pays d'installation et propose le meilleur miroir disponible sur Internet.



debian 12

Configurer l'outil de gestion des paquets

Veuillez choisir un miroir de l'archive Debian. Vous devriez utiliser un miroir situé dans votre pays ou votre région si vous ne savez pas quel miroir possède la meilleure connexion Internet avec vous.

Généralement, **deb.debian.org** est un choix pertinent.

Miroir de l'archive Debian :

- deb.debian.org
- ftp.fr.debian.org
- debian.proxad.net
- ftp.ec-m.fr
- deb-mir1.naitways.net
- miroir.univ-lorraine.fr
- ftp.u-picardie.fr
- ftp.u-strasbg.fr
- mirror.plusserver.com
- debian.mirror.ate.info
- debian.univ-tlse2.fr
- ftp.rezopole.net
- ftp.univ-pau.fr
- mirrors.ircam.fr

Capture d'écran Revenir en arrière Continuer

Il ne reste plus qu'à l'administrateur de sélectionner le miroir de son choix parmi la liste proposée.

debian 12

Configurer l'outil de gestion des paquets

Si vous avez besoin d'utiliser un mandataire HTTP (souvent appelé « proxy ») pour accéder au monde extérieur, indiquez ses paramètres ici. Sinon, laissez ce champ vide.

Les paramètres du mandataire doivent être indiqués avec la forme normalisée « **http://[utilisateur]:[mot-de-passe]@hôte[:port]/** ».

Mandataire HTTP (laisser vide si aucun) :

Capture d'écran Revenir en arrière Continuer

Si la configuration du réseau nécessite un serveur mandataire (proxy), l'assistant propose d'en nommer un, sinon il suffit de laisser le champ vide si ce n'est pas nécessaire.



debian 12

Configuration de popularity-contest

Le système peut envoyer anonymement aux responsables de la distribution des statistiques sur les paquets que vous utilisez le plus souvent. Ces informations influencent le choix des paquets qui sont placés sur le premier CD de la distribution.

Si vous choisissez de participer, un script enverra automatiquement chaque semaine les statistiques aux responsables. Elles peuvent être consultées sur <https://popcon.debian.org/>.

Vous pourrez à tout moment modifier votre choix en exécutant « dpkg-reconfigure popularity-contest ».

Souhaitez-vous participer à l'étude statistique sur l'utilisation des paquets ?

☒ Non

☐ Oui

Capture d'écran

Revenir en arrière

Continuer

Si l'on souhaite participer à l'évolution de la distribution, on peut choisir de fournir (ou non) les statistiques d'utilisation des packages téléchargés.

debian 12

Sélection des logiciels

Actuellement, seul le système de base est installé. Pour adapter l'installation à vos besoins, vous pouvez choisir d'installer un ou plusieurs ensembles prédéfinis de logiciels.

Logiciels à installer :

- ☒ environnement de bureau Debian
- ☒ ... GNOME
- ☐ ... Xfce
- ☐ ... bureau GNOME Flashback
- ☐ ... KDE Plasma
- ☐ ... Cinnamon
- ☐ ... MATE
- ☐ ... LXDE
- ☐ ... LXQt
- ☐ serveur web
- ☒ serveur SSH
- ☒ utilitaires usuels du système

Capture d'écran

Continuer

L'assistant propose de sélectionner les logiciels à installer en plus du socle de base, en cochant simplement les cases correspondant aux fonctionnalités souhaitées.



debian 12

Installer le programme de démarrage GRUB

Il semble que cette nouvelle installation soit le seul système d'exploitation existant sur cet ordinateur. Si c'est bien le cas, il est possible d'installer le programme de démarrage GRUB sur le disque principal (partition UEFI ou secteur d'amorçage).

Attention : si le programme d'installation ne détecte pas un système d'exploitation installé sur l'ordinateur, cela empêchera temporairement ce système de démarrer. Toutefois, le programme de démarrage GRUB pourra être manuellement reconfiguré plus tard pour permettre ce démarrage.

Installer le programme de démarrage GRUB sur le disque principal ?

☐ Non

☒ Oui

Capture d'écran

Revenir en arrière

Continuer

Le processus d'installation est presque terminé. Il reste à installer le chargeur de démarrage, et l'assistant propose automatiquement l'installation de GRUB.

debian 12

Installer le programme de démarrage GRUB

Le système nouvellement installé doit pouvoir être démarré. Cette opération consiste à installer le programme de démarrage GRUB sur un périphérique de démarrage. La méthode habituelle pour cela est de l'installer sur le disque principal (partition UEFI ou secteur d'amorçage). Vous pouvez, si vous le souhaitez, l'installer ailleurs sur un autre disque, une autre partition, ou même sur un support amovible.

Périphérique où sera installé le programme de démarrage :

Choix manuel du périphérique

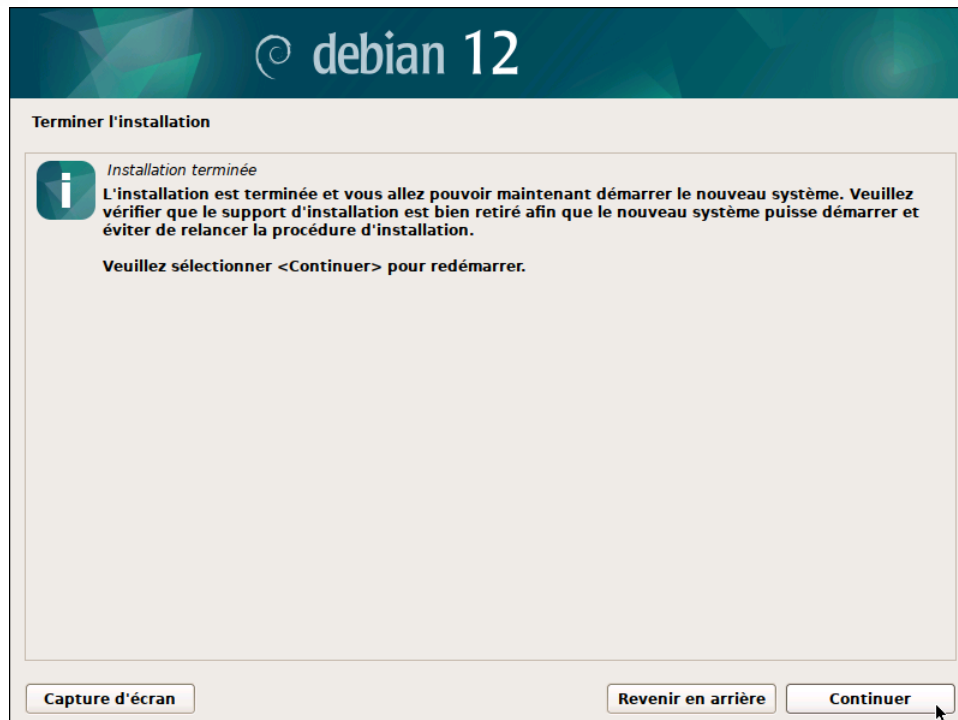
/dev/sda

Capture d'écran

Revenir en arrière

Continuer

Il faut sélectionner le disque sur lequel le secteur de démarrage sera installé, comme dans l'exemple où il s'agit du disque /dev/sda.



Enfin, l'assistant nous avertit que l'installation est terminée et que l'on peut désormais redémarrer le serveur sur le nouveau système.

```
netzia@Srv-zap: ~  
GNU nano 7.2 /etc/network/interfaces *  
# This file describes the network interfaces available on your system  
# and how to activate them. For more information, see interfaces(5).  
  
source /etc/network/interfaces.d/*  
  
# The loopback network interface  
auto lo  
iface lo inet loopback  
  
auto ens33  
iface ens33 inet static  
    address 192.168.1.26/24  
    gateway 192.168.1.1
```

Installation de Docker sur la machine hôte Debian 12.

```
apt install docker.io -y
```

Installe le paquet `docker.io`, qui contient la version communautaire de Docker, permettant de gérer des conteneurs sur le système.

- Activation et démarrage du service Docker



```
systemctl enable --now docker
```

Active le service Docker pour qu'il démarre automatiquement au boot (enable) et le lance immédiatement (--now).

- Ajout de l'utilisateur au groupe Docker

```
usermod -aG docker $USER
```

Ajoute l'utilisateur actuel (représenté par \$USER) au groupe docker, déconnexion/reconnexion est nécessaire pour que les changements de groupe prennent effet (commentaire, pas une commande exécutable).

- Vérification de la version de Docker

```
docker --version
```

```
root@Srv-zap:~# docker --version
Docker version 20.10.24+dfsg1, build 297e128
root@Srv-zap:~# █
```

Cette commande Affiche la version installée de Docker pour confirmer que l'installation a réussi.

Déploiement de DVWA avec la commande `docker run --rm -it -p 80:80 vulnerables/web-dvwa`.

DVWA (Damn Vulnerable Web Application) est une application web open-source conçue pour être intentionnellement vulnérable. Elle sert d'environnement d'entraînement pour apprendre les tests de sécurité web, avec des failles comme l'injection SQL, le XSS ou l'injection de commandes. Déployée facilement via Docker (ex. `docker run --rm -it -p 80:80 vulnerables/web-dvwa`), elle propose des niveaux de sécurité (Low, Medium, High, Impossible) pour tester et comprendre les vulnérabilités. Accès par défaut : admin/password sur <http://localhost/>.

- Lancement de DVWA avec Docker

```
docker run --rm -it -p 80:80 vulnerables/web-dvwa
```

Cette commande lance DVWA (Damn Vulnerable Web Application) dans un conteneur Docker, `docker run` crée et démarre le conteneur, `--rm` le supprime après arrêt (Ctrl+C), `-it` permet de voir les messages dans le terminal, `-p 80:80` rend DVWA accessible sur <http://localhost/> (ou <http://localhost:8080/>)



- Page d'authentification de DVWA



← → ↻ 🔒 📄 localhost/login.php 🚫 ☆ 📁



Username

admin

Password

●●●●●●●●

Login

Nous voici sur la page d'authentification de DVWA, accessible après avoir lancé le conteneur Docker (ex. `docker run --rm -it -p 80:80 vulnerables/web-dvwa`) et ouvert `http://localhost/` dans le navigateur. Par défaut, les identifiants sont admin (utilisateur) et password (mot de passe), permettant de se connecter à cette application volontairement vulnérable pour débiter les tests de sécurité."

➤ Page d'accueil de DVWA

[Home](#)[Instructions](#)[Setup / Reset DB](#)[Brute Force](#)[Command Injection](#)[CSRF](#)[File Inclusion](#)[File Upload](#)[Insecure CAPTCHA](#)[SQL Injection](#)[SQL Injection \(Blind\)](#)[Weak Session IDs](#)[XSS \(DOM\)](#)[XSS \(Reflected\)](#)[XSS \(Stored\)](#)[CSP Bypass](#)

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerability** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

DVWA also includes a Web Application Firewall (WAF), PHPIDS, which can be enabled at any stage to further increase the difficulty. This will demonstrate how adding another layer of security may block certain malicious actions. Note, there are also various public methods at bypassing these protections (so this can be seen as an extension for more advanced users)!

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

Nous voici sur la page d'accueil de DVWA, accessible après s'être connecté avec les identifiants par défaut admin (utilisateur) et password (mot de passe) sur <http://localhost/>, suite au lancement du conteneur Docker (`docker run --rm -it -p 80:80 vulnerables/web-dvwa`). Cette interface présente les différents modules vulnérables, comme l'injection SQL ou le XSS, prêts à être explorés pour les tests de sécurité."

Téléchargement et installation d'OWASP ZAP depuis le site officiel, lancement en mode Standard.

Téléchargez ZAP depuis :

<https://www.zaproxy.org/download/>

Rendez-vous sur le site officiel d'OWASP ZAP via ce lien pour récupérer la dernière version de l'outil. Choisissez la version adaptée à votre système (Windows, macOS, Linux ou Crossplatform) et téléchargez le fichier d'installation. Assurez-vous d'avoir Java 17+ installé (sauf pour la version macOS qui l'inclut) avant de lancer ZAP.

```
apt install openjdk-17-jdk
```

Installation et configuration de OWASP ZAP :



➤ Installation de ZAP sur Debian

Après obtention via le lien

```
wget https://github.com/zaproxy/zaproxy/releases/download/v2.16.1/ZAP_2.16.1_Linux.tar.gz
```

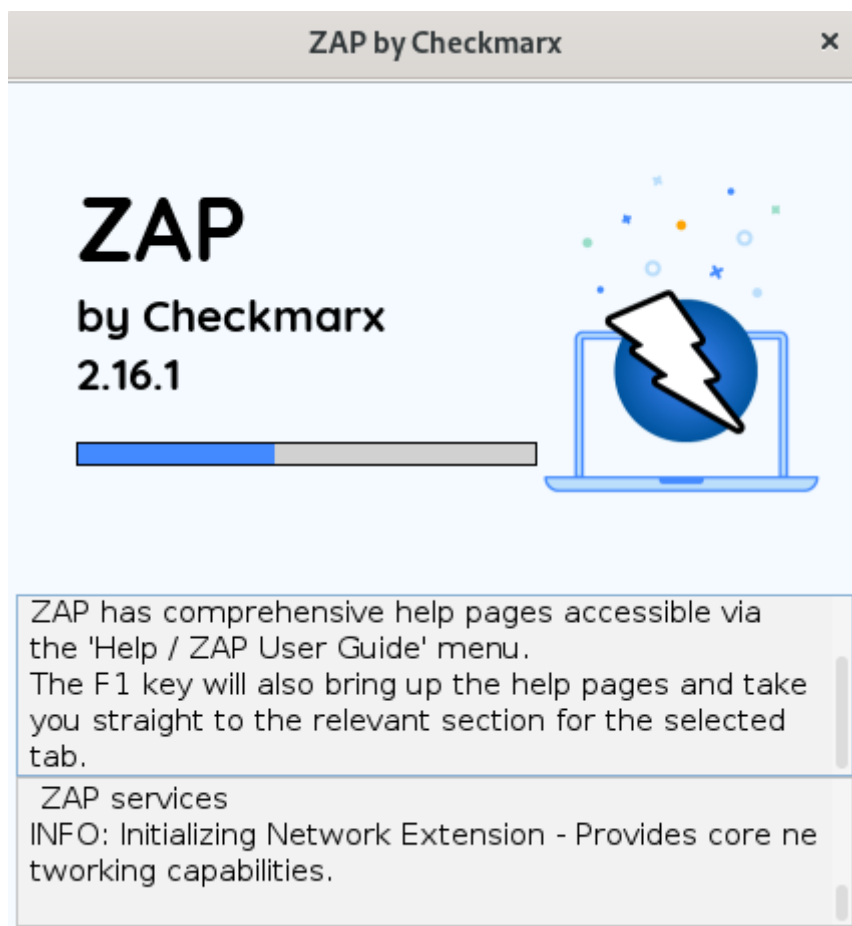
Une fois le fichier ZAP_2.16.1_Linux.tar.gz téléchargé depuis GitHub, ouvrez un terminal dans le dossier de téléchargement. Décompressez-le avec :

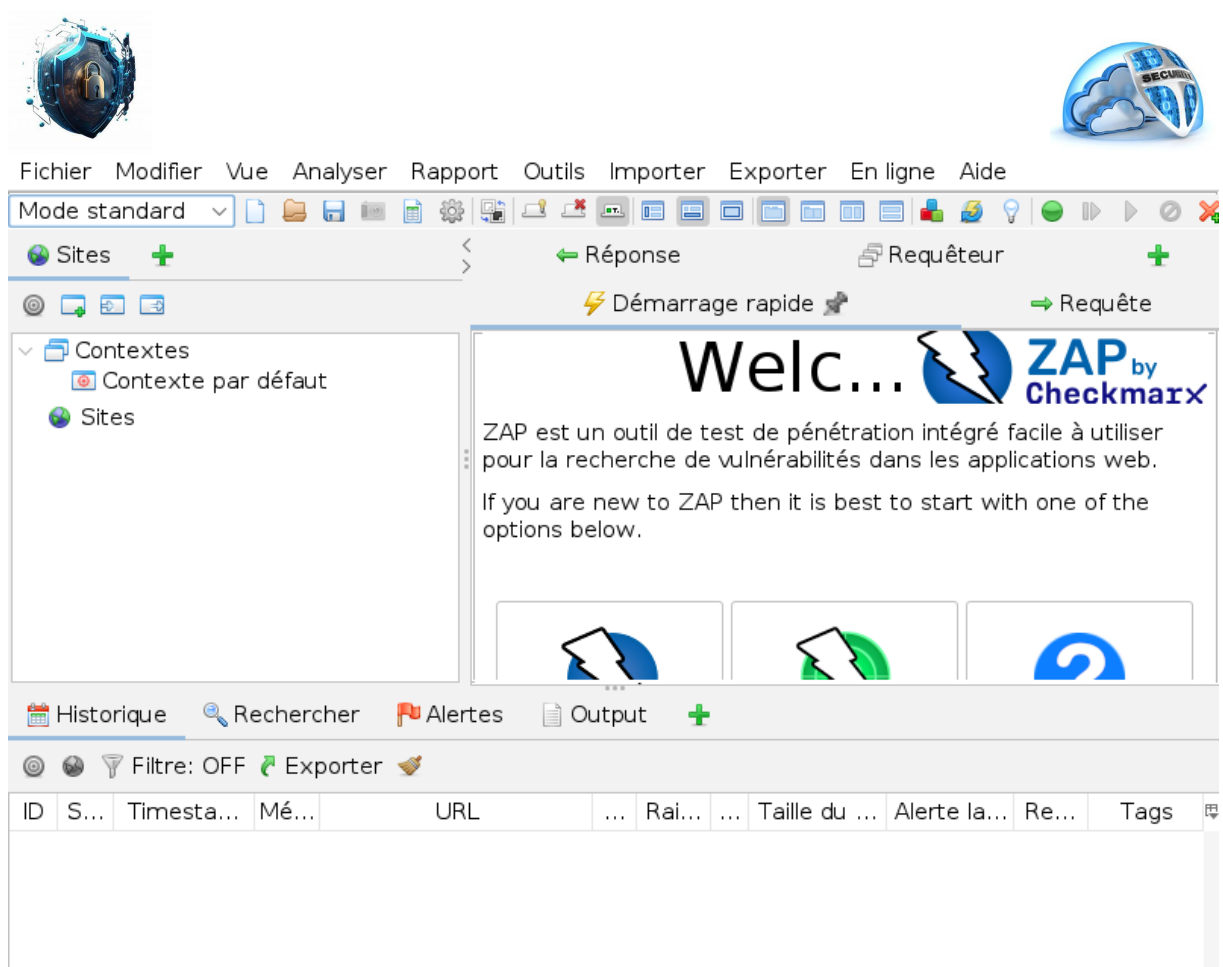
```
tar -xzf ZAP_2.16.1_Linux.tar.gz
```

Ouvrez votre navigateur et entrez cette URL :

```
http://localhost:8080/
```

Vous verrez une page de base indiquant que ZAP est actif.





Configuration du proxy dans Firefox (127.0.0.1, port 8080) ou utilisation du navigateur intégré à ZAP.



Paramètres de connexion



Configuration du serveur proxy pour accéder à Internet

- ☐ Pas de proxy
- ☐ Détection automatique des paramètres de proxy pour ce réseau
- ☐ Utiliser les paramètres proxy du système
- ☒ Configuration manuelle du proxy

Proxy HTTP Port

☒ Utiliser également ce proxy pour HTTPS

Proxy HTTPS Port

Hôte SOCKS Port

☐ SOCKS v4 ☒ SOCKS v5

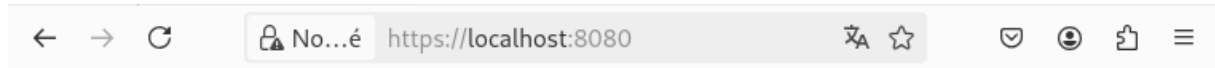
- ☐ Adresse de configuration automatique du proxy

Annuler

OK



- Vérification de l'interception du trafic en accédant à <http://localhost/>.



Attention : risque probable de sécurité

Firefox a détecté une menace de sécurité potentielle et n'a pas poursuivi vers **localhost**. Si vous accédez à ce site, des attaquants pourraient dérober des informations comme vos mots de passe, e-mails, ou données de carte bancaire.

Que pouvez-vous faire ?

Le problème vient probablement du site web, donc vous ne pouvez pas y remédier.

Si vous naviguez sur un réseau d'entreprise ou si vous utilisez un antivirus, vous pouvez contacter les équipes d'assistance pour obtenir de l'aide. Vous pouvez également signaler le problème aux personnes qui administrent le site web.

[En savoir plus...](#)

Retour (recommandé)

Avancé...



ZAPCACert.cer



Zed Attack Proxy Root CA

Identité: Zed Attack Proxy Root CA

Vérifié par: Zed Attack Proxy Root CA

Expire: 01/04/2026



► **Détails**

Fermer

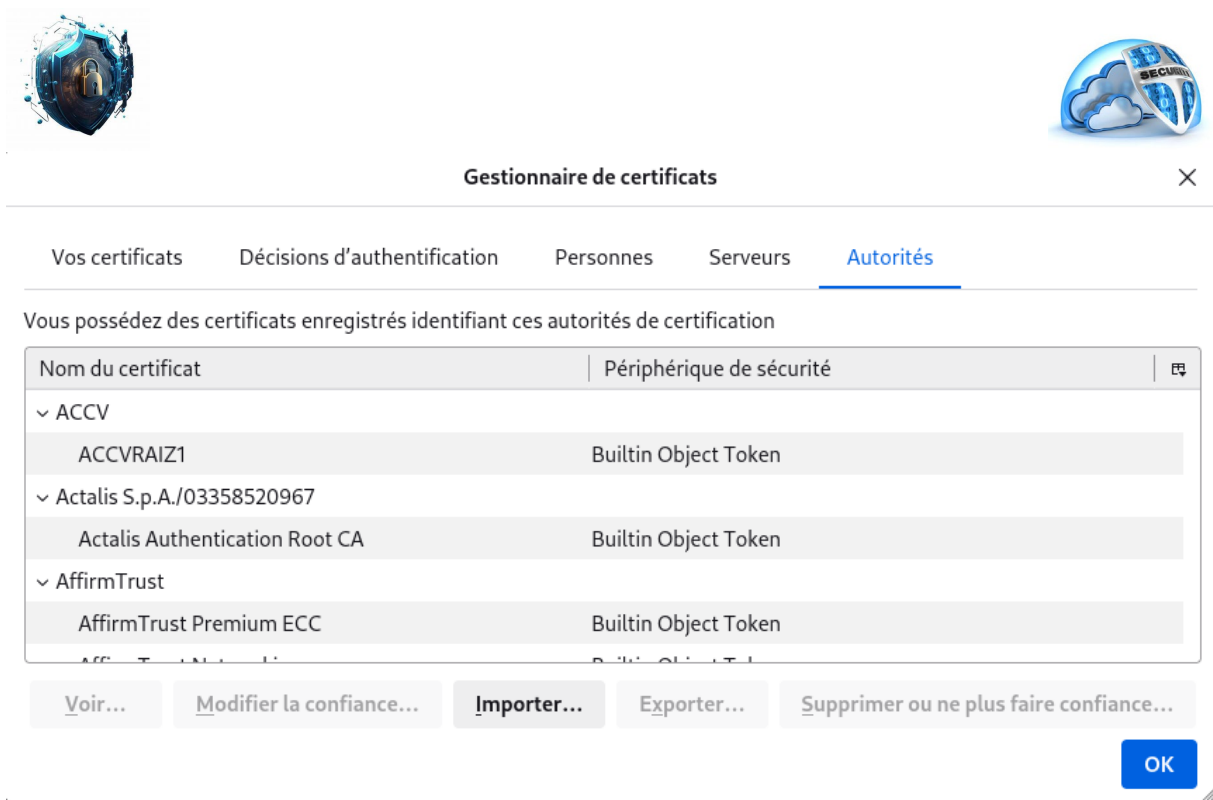
Importer

➤ **Accéder aux paramètres de sécurité :**

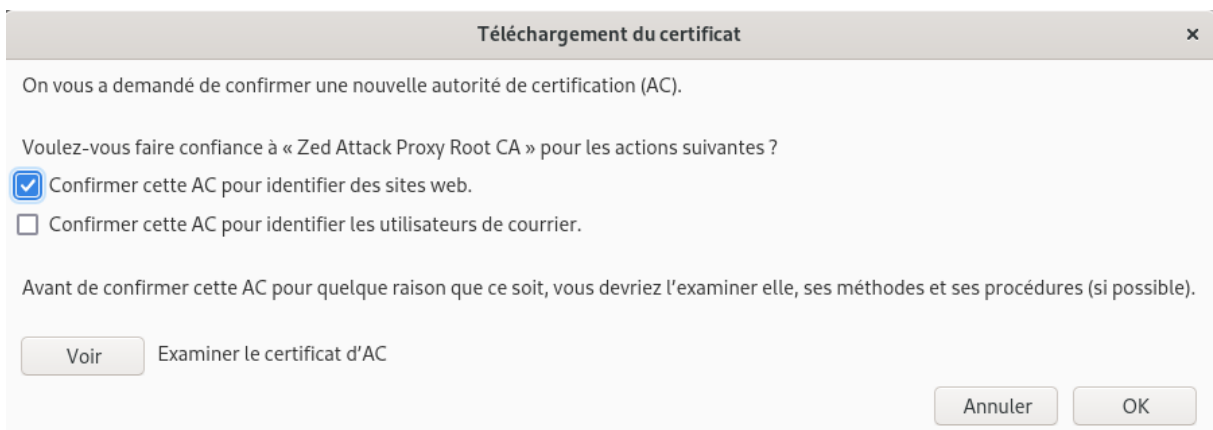
about:preferences#privacy

Dans la barre d'adresse, tapez about:preferences#privacy et appuyez sur **Entrée**, Faites défiler jusqu'à la section **Certificats**, qui est sous le bloc **Vie privée et sécurité**.

➤ **Afficher les certificats :**



Cliquez sur **Afficher les certificats**, Dans la fenêtre **Gestionnaire de certificats**, allez dans l'onglet **Autorités** et cliquez sur le bouton **Importer**.



Une fenêtre de sélection de fichier s'ouvrira. Sélectionnez le fichier **certificat** que vous avez téléchargé depuis ZAP, qui se trouve dans Téléchargements.

Une fois le certificat sélectionné, une boîte de dialogue apparaîtra avec des options. Cochez la case **Faire confiance à cette autorité de certification pour identifier les sites Web**.

➤ Confirmer l'importation :



Vous possédez des certificats enregistrés identifiant ces autorités de certification

Nom du certificat	Périphérique de sécurité	
OISTE WISeKey Global Root GA CA	Built-in Object Token	
OISTE WISeKey Global Root GB CA	Built-in Object Token	
▼ X Ramp Security Services Inc		
X Ramp Global CA Root	Built-in Object Token	
▼ ZAP Root CA		
Zed Attack Proxy Root CA	Sécurité personnelle	

Voir...

Modifier la confiance...

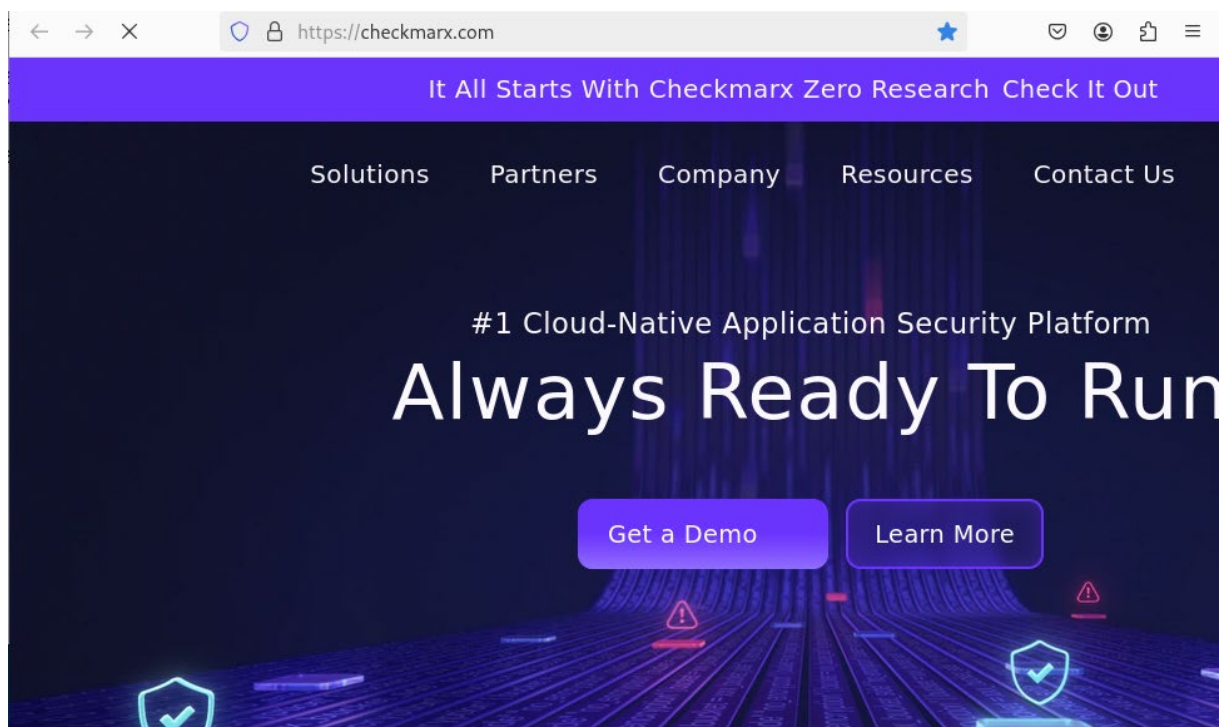
Importer...

Exporter...

Supprimer ou ne plus faire confiance...

OK

Cliquez sur **OK** pour ajouter le certificat.



Exploration de l'interface (arborescence des sites, historique, outils comme Spider et Fuzzer).

Intégration et exercices pratiques avec DVWA :

Connexion à DVWA (admin/password) et réglage du niveau de sécurité sur "Low".




Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

Low

PHPIDS

PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

PHPIDS works by filtering any user supplied input against a blacklist of potentially malicious code. It is used in DVWA to serve as a live example of how Web Application Firewalls (WAFs) can help improve security and in some cases how WAFs can be circumvented.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently: **disabled**. [\[Enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Réalisation d'exercices : injection SQL avec 1' OR '1'='1, XSS avec `<script>alert('XSS')</script>`, fuzzing sur le module Brute Force, injection de commandes avec 127.0.0.1 && whoami.



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Vulnerability: SQL Injection

User ID:

ID: 1
First name: admin
Surname: admin

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-okw/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

Tests préliminaires des vulnérabilités via ZAP (interception, modification des requêtes, analyse des réponses).